

Northstar Labs Secure Software Development Policy

Version 1.0 – Internal Policy Document

Northstar Labs is committed to developing secure, reliable, and resilient software solutions. This policy defines the organisation's secure software development expectations, including code review practices, CI/CD security controls, vulnerability management, penetration testing, and secure software development lifecycle (SDLC) requirements.

Document Owner	Engineering & Security Leadership
Company	Northstar Labs
Version	1.0
Review Frequency	Annually
Classification	Internal Use
Effective Date	18 May 2026

1. Secure Software Development Lifecycle (SDLC)

Northstar Labs follows a secure software development lifecycle (SDLC) that incorporates security considerations throughout the design, development, testing, deployment, and maintenance phases of software delivery. Security requirements should be considered during project planning and solution design. Development teams are expected to follow secure coding standards, minimise security risks, and address identified vulnerabilities promptly. Security controls and testing activities should be proportionate to the sensitivity and risk profile of the application or service.

2. Code Reviews

All production code changes must undergo peer review before deployment. Code reviews should assess: • Code quality and maintainability • Security risks and vulnerabilities • Authentication and authorisation logic • Error handling and logging • Compliance with internal development standards Direct commits to protected production branches are restricted unless formally approved for emergency remediation purposes.

3. CI/CD Security Controls

Northstar Labs uses automated CI/CD pipelines to support secure and consistent software delivery. CI/CD pipelines should include: • Automated build validation • Dependency and package scanning • Automated testing • Secrets detection • Deployment approval controls where appropriate Access to CI/CD platforms must be restricted to authorised personnel and protected using multi-factor authentication (MFA). Deployment pipelines should maintain audit logs for deployment activity and configuration changes.

4. Vulnerability Scanning

Applications, infrastructure, and dependencies are subject to regular vulnerability scanning to identify security weaknesses and outdated software components. Vulnerability scanning activities may include: • Dependency scanning • Container image scanning • Infrastructure scanning • Static application security testing (SAST) • Dynamic application security testing (DAST) Identified vulnerabilities should be prioritised and remediated based on severity and business risk.

5. Penetration Testing

Northstar Labs conducts penetration testing on customer-facing applications and critical systems periodically or following significant architectural changes. Penetration testing may be performed by qualified internal personnel or approved third-party security specialists. Findings from penetration tests must be documented, reviewed, and tracked through remediation to completion. High and critical security findings should be addressed within defined remediation timelines.

6. Security Monitoring and Continuous Improvement

Security processes, tooling, and development practices are reviewed periodically to support continuous improvement and evolving threat landscapes. Lessons learned from incidents, testing activities, and security assessments should be incorporated into development standards and engineering practices. Employees involved in software development are expected to maintain awareness of secure coding principles and emerging security risks.